

Advanced System Audit Report

Repository: `C:\Users\Kutay\Desktop\move-main\move-main`

Audit date: 2026-05-30

Branch: `feat/connector-and-workspace-foundation`

Latest commit reviewed: `51f7bb3a15f5443facf7e074c1f239110f0894f4` - `fix(workspace): enforce read-only gate on leave/restore/revoke + invite email language`

Last 3 days: `77` commits were present in the local Git history. The recent change stream is concentrated around Workspace/Family-Pro, connector dispatch, billing plan changes, admin hardening, mobile invite deep links, and observability.

Audit Rules Followed

- Existing repository `.md` files were not read or used as audit sources.
- This report was produced from code, config, manifests, Prisma schema/migrations, package manifests, tests, and build/deploy files.
- If a claim could not be confirmed from code/config, it is marked as low confidence or "not proven from code".
- Internet/CVE claims are not made. Dependency risk is based only on local manifests/lock/config and executed local commands.

Executive Summary

The system is a mature TypeScript monorepo with strong baseline controls: Next.js route handlers, Prisma data model, shared entitlement logic, admin RBAC, CSRF/CSP/rate-limit middleware, connector outbox architecture, webhook validation surfaces, and broad Vitest coverage. The latest work added major Family/Pro workspace and connector capabilities, but those new surfaces are also where the highest risk sits.

No confirmed critical remote-code-execution style issue was found. The most important risks are:

- High: connector auto-dispatch can bypass the intended annual Pro entitlement.
- High: workspace sync can include a `fromAddressId` from outside the workspace or from soft-deleted history.
- High: `/api/profile` returns the raw selected `subscription` object, while that select includes Google Play `purchaseToken`.
- High: mobile purchase tokens are stored in plaintext even though the codebase already has field-level encryption patterns for connector tokens.

- Medium: Family/Pro billing and UI are only partially generalized; several settings components still hardcode Individual labels/prices, and scheduled plan changes do not persist target plan.
- Medium: Workspace seat limits, ownership transfer, destructive actions, and on-behalf sync need stronger atomicity and step-up controls.
- Medium: Android native config is stale versus Expo config, so invite app links and app-lock/permission readiness can drift in release builds.

Verification Commands

All commands completed successfully except the noted engine warning:

Command	Result
pnpm --filter @locateflow/web test	Passed: 175 files, 1227 tests
pnpm --filter @locateflow/admin test	Passed: 78 files, 427 tests
pnpm --filter @locateflow/mobile test	Passed: 9 files, 21 tests
pnpm --filter @locateflow/mobile lint	Passed: tsc --noEmit
pnpm --filter @locateflow/connectors test	Passed: 11 files, 72 tests
pnpm --filter @locateflow/shared exec vitest run	Passed: 23 files, 201 tests
pnpm verify:typecheck	Passed for web, admin, mobile, db, connectors

Environment warning on every pnpm command: repo wants Node `22.x`, local runtime was Node `v24.12.0`.

Project Map

Area	Main Paths	Technology	Entry / Important Files	Risk
Web app	apps/web	Next.js 16, React 19, Prisma, Stripe, Sentry, Upstash	apps/web/src/app, apps/web/src/middleware.ts, apps/web/src/lib/*	High
Admin app	apps/admin	Next.js 16, React 19, Prisma, admin RBAC	apps/admin/src/app, apps/admin/src/middleware.ts, apps/admin/src/lib/auth.ts	High
Mobile app	apps/mobile	Expo 55, React Native 0.83, Expo Router, StoreKit/Play IAP	apps/mobile/app.json, apps/mobile/app, apps/mobile/src/lib/api.ts	High
Shared domain	packages/shared	TypeScript, Zod	billing.ts, entitlement.ts, permissions.ts, workspace-entitlements.ts, runtime-config.ts	High
Database	packages/db	Prisma 5, MySQL target, migrations	packages/db/prisma/schema.prisma, packages/db/prisma/migrations	High
Connectors	packages/connectors	TypeScript connector framework	src/core/http-client.ts, src/core/manifest.ts, src/core/state.ts	High
Deploy/build	root, docker	app configs pnpm, Turbo, Docker, Vercel/EAS	package.json, turbo.json, Dockerfile, apps/mobile/eas.json	Medium

Static inventory, excluding .md: apps 1120 files, packages 160 files, docs 106 non-

md artifacts, `scripts` 27 files, `docker` 7 files.

API inventory:

App	Route Files	Method Exports
Web	133	GET 81, POST 79, PATCH 13, PUT 4, DELETE 8
Admin	75	GET 49, POST 44, PATCH 13, PUT 6, DELETE 13

Positive Controls Observed

- Web middleware has explicit CSRF handling for mutating requests, route-based public API allowlists, nonce-based CSP, rate-limit policies, and JWT prefiltering.
- Admin middleware requires `ADMIN\_JWT\_SECRET`, uses secure headers/CSP, has IP blocking/break-glass paths, and route-level `requireAdmin`/`requirePermission` helpers.
- Admin `requireAdmin` and `requirePermission` re-check DB session/user state instead of trusting only middleware JWT.
- Stripe, App Store, and Play Store billing state is centralized through shared entitlement helpers and tests.
- Connector dispatch uses an outbox model and atomic `QUEUED -> DISPATCHING` claim to reduce duplicate sends.
- Partner consent tokens are encrypted in `PartnerConsent` with `tokenEncrypted` and `refreshTokenEncrypted`.
- Test coverage is substantial for web/admin/shared/connectors.

High Findings

H-01: Auto Connector Dispatch Bypasses Pro/Annual Entitlement

Evidence:

- `apps/web/src/app/api/addresses/[id]/route.ts:101-102` enqueues connector sync when a primary address changes and connectors are globally enabled.
- `apps/web/src/lib/connector-runtime.ts:115-126` `enqueueAddressChange` loads addresses, user, granted consents, and connector configs but has no `userHasApiConnectorEntitlement` check.
- `apps/web/src/app/api/connector-dispatch/route.ts:21-25` shows the manual dispatch route does enforce `isApiConnectorsEnabled` and `userHasApiConnectorEntitlement`.

Impact:

A downgraded, expired, monthly Pro, Family, or Individual user who still has an existing granted consent can trigger partner updates through address edits even though the feature is meant to be annual Pro-only.

Exploit / failure path:

1. User previously grants connector consent while eligible.
2. User loses annual Pro entitlement.
3. User edits primary address.
4. Auto enqueue path still creates dispatch rows for granted consents.

Fix:

Centralize entitlement checks inside `enqueueAddressChange`, because every enqueue path flows through it. Route-level checks should remain as defense-in-depth.

Suggested patch shape:

```
``ts
if (!(await isApiConnectorsEnabled())) throw new Error("CONNECTORS_DISABLED");
if (!(await userHasApiConnectorEntitlement(input.userId))) {
  throw new Error("CONNECTOR_ENTITLEMENT_REQUIRED");
}
``
```

Add regression tests for auto-sync from address update, workspace sync, manual sync, downgraded Pro, monthly Pro, Family, Individual, and free trial.

H-02: Workspace Sync Can Leak `fromAddressId` Across Workspace Boundaries

Evidence:

- `apps/web/src/app/api/workspaces/[id]/sync/route.ts:77-87` validates only `toAddressId` and only rejects mismatched non-null `workspaceId`.
- `apps/web/src/app/api/workspaces/[id]/sync/route.ts:90` passes `fromAddressId` to `enqueueAddressChange`.
- `apps/web/src/lib/connector-runtime.ts:121-124` loads `fromAddress` by `{ id, userId }` with no `deletedAt: null` and no `workspaceId` guard.
- `packages/db/prisma/schema.prisma:431-434` confirms `Address.workspaceId` is nullable during Workspace Phase 1.

Impact:

A permitted workspace sync can include origin-address PII from another workspace or from soft-deleted history in an external connector payload.

Exploit / failure path:

An owner/admin starts a workspace sync for a member and supplies a known `fromAddressId`

belonging to that same user but outside the current workspace. The destination address passes validation, then runtime fetches the origin address without workspace isolation.

Fix:

Validate both `toAddressId` and `fromAddressId` against the same workspace and `deletedAt: null`. During the nullable migration phase, either block null `workspaceId` for workspace sync or route nulls through a controlled backfill-only path.

H-03: `/api/profile` Exposes Raw Subscription Object Including Purchase Token

Evidence:

- `apps/web/src/lib/billing.ts:191-220` defines `SUBSCRIPTION\_ENTITLEMENT\_SELECT`; line `206` selects `purchaseToken: true`.
- `apps/web/src/app/api/profile/route.ts:85-99` returns `subscription` directly in JSON at line `93`.
- `packages/db/prisma/schema.prisma:247-248` stores both `purchaseToken` and `purchaseTokenHash`.

Impact:

An authenticated client can receive raw Google Play purchase tokens if present on the subscription row. Purchase tokens are provider credentials for subscription lookup/acknowledgement flows and should not be exposed to web/mobile clients.

Fix:

Return a sanitized subscription DTO from `/api/profile`. Keep `purchaseToken`, transaction identifiers not needed by UI, internal Stripe IDs, and schedule IDs server-only unless the UI has a specific safe need.

Suggested patch shape:

```
``ts
function publicSubscriptionDto(subscription: SubscriptionEntitlementRecord | null) {
  if (!subscription) return null;
  return {
    plan: subscription.plan,
    status: subscription.status,
    provider: subscription.provider,
    platform: subscription.platform,
    billingInterval: subscription.billingInterval,
    currentPeriodEndsAt: subscription.currentPeriodEndsAt,
    cancelAtPeriodEnd: subscription.cancelAtPeriodEnd,
```

```
    pendingBillingInterval: subscription.pendingBillingInterval,  
    pendingBillingIntervalEffectiveAt: subscription.pendingBillingIntervalEffectiveAt,  
  };  
}  
...
```

H-04: Raw Mobile Purchase Tokens Are Stored Plaintext

Evidence:

- `packages/db/prisma/schema.prisma:247` stores `purchaseToken String? @db.Text`.
- `packages/db/prisma/schema.prisma:248` also stores a unique `purchaseTokenHash`.
- `packages/db/prisma/schema.prisma:1731-1732` shows the codebase already encrypts connector access/refresh tokens.
- `apps/web/src/lib/iap-common.ts` writes and reads raw `purchaseToken` in several IAP paths.

Impact:

Database read access exposes raw Google Play purchase tokens. This expands blast radius during database leaks, backup mishandling, admin debugging, or accidental JSON serialization.

Fix:

Prefer hash-only lookup plus encrypted raw token only where Google API refresh absolutely requires it. Rename to `purchaseTokenEncrypted`, encrypt with `FIELD\_ENCRYPTION\_KEY`, and keep `purchaseTokenHash` for lookup/dedupe. Migrate existing rows.

Medium Findings

M-01: Active Entitlement Can Stay Premium After Period End

Evidence:

- `packages/shared/src/entitlement.ts:322-359` computes `periodActive` for `ACTIVE`, but only denies access when `!periodActive && subscription.canceledAt`.
- If `status === "ACTIVE"`, `currentPeriodEndsAt` is expired, and `canceledAt` is null, line `343-359` still returns `hasAccess: true` and `hasPremium: true`.

Impact:

If a webhook/reconcile job misses a transition, a provider-paid subscription can remain premium indefinitely.

Fix:

For provider-paid rows, fail closed or enter grace when ``currentPeriodEndsAt`` is expired unless a fresh provider validation proves active renewal. Use ``lastSyncedAt`` freshness and explicit provider status as part of the decision.

M-02: Family/Pro Price Runtime Config Is Referenced but Not Fully Declared**Evidence:**

- ``packages/shared/src/billing.ts:137-140`` defines ``STRIPE_PRICE_FAMILY_MONTHLY``, ``STRIPE_PRICE_FAMILY_YEARLY``, ``STRIPE_PRICE_PRO_MONTHLY``, ``STRIPE_PRICE_PRO_YEARLY``.
- ``apps/web/src/lib/billing.ts:61-96`` resolves those keys for Family/Pro checkout.
- ``packages/shared/src/runtime-config.ts:53-63`` and ``227-259`` list only Individual Stripe price keys.
- ``.env.production.example:127-128`` and ``docker-compose.prod.yml:111-112`` expose only Individual Stripe price keys.

Impact:

Family/Pro self-serve checkout and plan change can return ``503 PLAN_NOT_AVAILABLE`` or webhook price-to-plan mapping can fail unless undeclared environment variables are set manually.

Fix:

Add all Family/Pro Stripe price IDs to runtime-config definitions, production env examples, Docker compose, validation checks, and billing tests.

M-03: Family/Pro Subscription Settings Still Hardcode Individual Labels and Prices**Evidence:**

- ``apps/web/src/components/settings/subscription-management.tsx:88-103`` returns ``"Individual Annual Trial"`` and ``"Individual"`` for active/cancel states.
- ``apps/web/src/components/settings/subscription-management.tsx:633-636`` uses ``BILLING_PLAN_DEFINITIONS.INDIVIDUAL`` for cycle switch price math.
- Related analytics/cancellation events also hardcode ``individual`` in the same component.

Impact:

Family and Pro users can see wrong plan names, wrong cycle price messaging, and inaccurate analytics. This is a customer-visible billing correctness issue.

Fix:

Derive display copy and prices from `subscription.plan` or `entitlement.effectivePlan`, not Individual constants. Add Family/Pro UI tests for active, cancel-at-period-end, grace, scheduled downgrade, and portal flows.

M-04: Scheduled Family/Pro Tier Changes Do Not Persist Target Plan

Evidence:

- `packages/db/prisma/schema.prisma:256-257` has only `pendingBillingInterval` and `pendingBillingIntervalEffectiveAt`; no `pendingPlan`.
- `apps/web/src/app/api/subscription/change-plan/route.ts:293-313` stores Stripe schedule ID and pending interval, not target plan.
- `apps/web/src/app/api/subscription/change-plan/route.ts:336-344` returns `pendingPlan` only in the immediate response.

Impact:

After refresh, the UI cannot reliably show whether a scheduled downgrade is Pro -> Family, Family -> Individual, or same-tier cycle switch. Seat warnings and support/audit context can become ambiguous.

Fix:

Add `pendingPlan` and `pendingPlanEffectiveAt` or a normalized subscription scheduled-change table. Clear it from webhook when the target price becomes active.

M-05: Family/Pro Checkout Pending Rows Do Not Persist Plan/Provider/Access Type on Existing Rows

Evidence:

- `apps/web/src/app/api/stripe/checkout/route.ts:158-162` creates a new subscription with `{ userId, plan, status: "PENDING\_CHECKOUT", provider: "STRIPE", platform: "web" }`.
- `apps/web/src/app/api/stripe/checkout/route.ts:186-198` updates existing rows to `PENDING\_CHECKOUT`, `billingInterval`, `stripePriceId`, and policy versions, but does not set `plan`, `provider`, `platform`, or `accessType`.

Impact:

A user upgrading from free/trial/manual states can temporarily hold a local row that says one plan/source while its checkout price indicates another. If the checkout is abandoned or webhook delayed, UI/support state can be misleading.

Fix:

Store `pendingPlan`, `pendingProvider`, and `pendingPriceId`, or set a consistent pending state that the entitlement/UI layer understands.

M-06: Past-Due/Grace Stripe Subscribers Can Start New Checkout

Evidence:

- `apps/web/src/app/api/stripe/checkout/route.ts:120-129` blocks only `ACTIVE`, `CANCEL\_AT\_PERIOD\_END`, and `TRIALING` real Stripe subscriptions.
- Store-managed subscriptions use broader `MANAGED\_SUBSCRIPTION\_BLOCKING\_STATUSES` at `apps/web/src/app/api/stripe/checkout/route.ts:135-139`.
- `apps/web/src/components/settings/plan-change-section.tsx:50-54` similarly treats only active/cancel/trial as Stripe-managed.

Impact:

Past-due or grace-period Stripe users can be routed to create a new checkout instead of resolving the existing subscription in Stripe Portal. This can produce duplicate subscriptions or bypass dunning expectations.

Fix:

Use the same blocking status set for Stripe-managed rows or send all rows with an existing `stripeSubscriptionId` to the portal/change-plan flow.

M-07: Pro Monthly Purchase Conflicts With Annual-Pro Connector Gate

Evidence:

- Recent billing logic gates API connectors to active annual Pro.
- `apps/web/src/components/settings/plan-change-section.tsx:156-158` advertises "Automatic connections require annual Pro."
- Family/Pro checkout and plan-change code supports Pro monthly price IDs.

Impact:

Pro monthly can be purchased while a core Pro feature remains unavailable. That may be valid packaging, but the UI/checkout must make it explicit before purchase.

Fix:

Either rename Pro monthly benefits clearly or block Pro monthly when the selected feature is automatic connectors. Add plan comparison tests for Individual, Family, Pro monthly, and Pro annual.

M-08: Workspace Seat Limits Are Raceable

Evidence:

- ``apps/web/src/app/api/workspaces/[id]/invitations/route.ts:78-87`` checks seats before insert.
- ``apps/web/src/app/api/workspaces/[id]/invitations/route.ts:102-103`` creates invitation after the check.
- ``apps/web/src/app/api/invitations/[token]/accept/route.ts:39-46`` counts members inside a transaction but without row lock/serializable isolation.

Impact:

Parallel invites or accepts can exceed Family/Pro seat caps until later reconciliation.

Fix:

Use a seat ledger, workspace row lock, or serializable transaction. Run ``reconcileWorkspaceSeats`` after accept as defense-in-depth and add concurrent tests.

M-09: Destructive Workspace Actions Lack Step-Up Auth

Evidence:

- ``apps/web/src/app/api/workspaces/[id]/delete/route.ts:13`` comments that ``WorkspaceAuthChallenge`` step-up is deferred.
- ``packages/db/prisma/schema.prisma:1915-1924`` already models step-up challenges for ``ROLE_OWNER_CHANGE`` and ``WORKSPACE_DELETE``.
- Transfer route checks owner and target only, without consuming a challenge.

Impact:

A stolen active web session can delete a workspace or transfer ownership without fresh password/MFA proof.

Fix:

Require a fresh ``WorkspaceAuthChallenge`` for workspace delete, member remove, and ownership transfer. Test missing, expired, consumed, and wrong-purpose challenges.

M-10: On-Behalf Workspace Sync Allows Suspended/Overflow and Nullable-Workspace Edge Cases

Evidence:

- `apps/web/src/app/api/workspaces/[id]/sync/route.ts:60-69` checks target membership and managed-sync consent but not target member `status`.
- `packages/shared/src/permissions.ts:173-179` defaults CHILD managed sync to enabled.
- `apps/web/src/app/api/workspaces/[id]/sync/route.ts:83-87` intentionally allows null `workspaceId`.

Impact:

Owner/admin sync can act for suspended/overflow targets, and during migration can act on addresses not bound to the workspace.

Fix:

Require target status `ACTIVE` and require `address.workspaceId === id` whenever workspace sync is enabled outside a backfill-only migration path.

M-11: Consent Revocation Races With In-Flight Dispatch

Evidence:

- `apps/web/src/lib/connector-oauth.ts:220-246` revokes consent and marks queued/in-flight dispatches `NEEDS\_USER`.
- `apps/web/src/lib/connector-runtime.ts:265-285` later writes worker result back unconditionally for the row.

Impact:

If a user revokes consent while a worker is calling a partner, the worker can still record `SUBMITTED` or `CONFIRMED` afterward.

Fix:

Re-check consent immediately before partner call and condition final update on `{ id: row.id, status: "DISPATCHING" }` plus consent still `GRANTED`.

M-12: OAuth Token Exchange Bypasses Connector SSRF Controls

Evidence:

- `apps/web/src/lib/connector-oauth.ts:70-83` accepts runtime-config `authorizeUrl` and `tokenUrl`.
- `apps/web/src/lib/connector-oauth.ts:99-118` uses raw `fetch(config.tokenUrl)`.
- `packages/connectors/src/core/http-client.ts:87-100` has HTTPS and allowlist checks, but OAuth exchange does not use it.

Impact:

Runtime config compromise or misconfiguration can cause server-side requests to unintended hosts, including internal services, and lacks connector HTTP timeout/redirect hardening.

Fix:

Validate OAuth URLs against connector manifest allowlists. Enforce HTTPS, block private/link-local/loopback IPs after DNS resolution, set explicit timeout, and reject redirects outside the allowlist.

M-13: Connector Allowlists Do Not Reject Private Hosts/IPs**Evidence:**

- `packages/connectors/src/core/manifest.ts:37-40` only checks host lowercase/no slash/no spaces.
- `packages/connectors/src/core/http-client.ts:95-100` checks HTTPS and exact host match only.

Impact:

A connector manifest can allow `127.0.0.1`, private IPs, or DNS names resolving internally. If manifests are admin-controlled, this becomes an SSRF defense gap.

Fix:

Reject localhost, private IP literals, link-local, and internal domains at manifest validation. At request time, resolve hostnames and block private network destinations.

M-14: Active PartnerConsent Uniqueness Is Application-Only**Evidence:**

- `packages/db/prisma/schema.prisma:1742-1744` has non-unique indexes for PartnerConsent.
- `apps/web/src/lib/connector-oauth.ts:181-203` does `findFirst` then create/update.

Impact:

Concurrent OAuth callbacks can create duplicate active grants for the same `(userId, connectorKey)`, which can confuse revocation, dispatch selection, and consent UI.

Fix:

Add DB-level uniqueness for active grants, or use a transactional lock/normalized current-consent pointer. Add concurrent callback tests.

M-15: Stuck `DISPATCHING` Rows Have No Proven Recovery Path

Evidence:

- `apps/web/src/lib/connector-runtime.ts:293-307` selects only `QUEUED` rows.
- `apps/web/src/lib/connector-runtime.ts:323-325` says a recovery sweep handles `DISPATCHING`, but no matching sweep was found in code search.

Impact:

Process crash after claim can strand dispatch rows forever.

Fix:

Add stale `DISPATCHING` requeue/reconcile job with max age, attempt count, and tests.

M-16: Admin Dashboard Exposes Sensitive Business Data to Any Active Admin

Evidence:

- `apps/admin/src/app/(admin)/layout.tsx:12-15` calls only `requirePageAdmin`.
- `apps/admin/src/app/(admin)/page.tsx:47-62` directly queries users, subscriptions, moving plans, upcoming moves, and user address summaries.
- `apps/admin/src/app/(admin)/page.tsx:141-150` renders KPI cards including MRR, ARPU, and paid subscription counts.

Impact:

VIEWER/MODERATOR accounts can see financial and operational data that other analytics APIs appear to guard more strictly.

Fix:

Gate dashboard cards by permission, raise page minimum role, or move sensitive dashboard data behind guarded APIs.

M-17: Admin User Detail Endpoint Returns Broad PII to VIEWER-Level Readers

Evidence:

- `apps/admin/src/app/api/users/[id]/route.ts:281-287` allows `users.canRead` with minimum `VIEWER`.

- `apps/admin/src/app/api/users/[id]/route.ts:309-336` includes profile, addresses, services, moving plans, and move tasks.
- `apps/admin/src/app/api/users/[id]/route.ts:391-395` includes budgets and support tickets.
- `apps/admin/src/lib/privacy.ts:150-219` redacts tokens/IP/admin notes, but not nested address, budget, profile, or support detail.

Impact:

Lower admin roles can retrieve detailed household/move/profile/budget data for arbitrary users.

Fix:

Use role-specific Prisma selects and redaction. Make full detail ADMIN-only; provide a minimal VIEWER DTO.

M-18: Blog Image Sanitizer Allows Protocol-Relative External URLs

Evidence:

- `apps/admin/src/lib/blog-content.ts:69-83` accepts images when `src.startsWith("/")`.
- `//evil.example/x.png` also starts with `/`.
- `apps/admin/src/app/api/blog/posts/[id]/route.ts:154-170` persists sanitized rendered HTML.

Impact:

Stored blog content can retain external tracking pixels or bypass intended image-origin controls.

Fix:

Reject protocol-relative URLs and restrict relative image URLs to approved local image proxy paths.

M-19: Admin Break-Glass IP Bypass Event Is Emitted but Rejected

Evidence:

- `apps/admin/src/middleware.ts:470-479` emits `IP\_RULE\_BYPASSED\_FOR\_BREAK\_GLASS`.
- `apps/admin/src/app/api/internal/security-event/route.ts:15-25` accepts only `BLOCKED\_IP\_ATTEMPT` and `SESSION\_HIJACK\_ATTEMPT`.
- `apps/admin/src/lib/security-monitor.ts:14-23` lacks the break-glass event type.

Impact:

Break-glass probing from blocked IPs is not persisted as intended, weakening incident visibility.

Fix:

Add a first-class event type, persistence handling, and a middleware-to-internal-route test.

M-20: Reports API Returns Internal Exception Messages**Evidence:**

- `apps/admin/src/app/api/reports/route.ts:87-91` returns `{ error: "Internal error", detail: e.message }`.

Impact:

Admins with report access can receive Prisma/schema/runtime details if they trigger errors.

Fix:

Return generic errors to clients; keep details in logs/Sentry. Validate date/type parameters before querying.

M-21: Android Native Manifest Is Stale Versus Expo Config**Evidence:**

- `apps/mobile/app.json:125-138` declares `/invitations` app links.
- `apps/mobile/android/app/src/main/AndroidManifest.xml:37-45` declares blog/oauth/reset-password links only.
- `apps/mobile/package.json:29-32` disables Expo doctor app-config sync checks.

Impact:

Android release builds may not open invite universal links, even though app.json says they should.

Fix:

Re-run/sync prebuild or manually update the native manifest. Re-enable Expo doctor config sync checks in CI.

M-22: iOS Privacy Manifest Declares No Collected Data

Evidence:

- `apps/mobile/app.json:31-35` sets `NSPrivacyCollectedDataTypes: []`.
- Mobile sign-up/profile/address flows collect account, profile, and address data.

Impact:

App Store privacy metadata can be under-disclosed if App Store Connect answers follow this manifest.

Fix:

Align `NSPrivacyCollectedDataTypes` and App Store privacy answers with actual account/profile/address collection.

M-23: Mobile Push Settings Cannot Enable Push After Deferred Soft Prompt

Evidence:

- `apps/mobile/app/settings/notifications.tsx:64-74` calls `registerForPushNotifications()` with default options.
- `apps/mobile/src/lib/push.ts:105-120` defaults `requireSoftPrompt` to true and returns false unless the stored decision is `"accepted"`.

Impact:

Users who deferred onboarding notifications can get a generic network error when explicitly enabling push in Settings.

Fix:

From Settings, call `registerForPushNotifications({ requireSoftPrompt: false })` after explicit user intent, or set the soft-prompt decision to accepted before registration.

M-24: Mobile Push/Notification Deep-Link Handling Is Incomplete

Evidence:

- `apps/mobile/src/lib/push.ts:47-55` sets foreground notification behavior.
- `apps/mobile/app/notifications/index.tsx:21-27` models `href`.
- `apps/mobile/app/notifications/index.tsx:169-172` row press only marks read and does not navigate.

Impact:

Tapping push/feed items does not route users to the intended screen.

Fix:

Add a notification response listener at root setup and route allowlisted `href` values. Reuse the same handler for feed rows after marking read.

M-25: Mobile Auth Guard Lets Tabs Mount While Onboarding State Is Unknown**Evidence:**

- `apps/mobile/app/(auth)/sign-in.tsx:118-124` sets session then routes to `/(tabs)`.
- `apps/mobile/app/\_layout.tsx:161-164` begins profile/onboarding fetch.
- `apps/mobile/app/\_layout.tsx:201-205` returns while `needsOnboarding === null`.
- `apps/mobile/app/(tabs)/index.tsx:54-58` immediately fetches profile, addresses, and moving data.

Impact:

New/incomplete accounts can briefly mount app surfaces before onboarding/legal state is settled.

Fix:

Render a blocking loading state until user and onboarding state are known, or route password sign-in through onboarding until confirmed complete.

M-26: Mobile Preview Builds Use Production API URL**Evidence:**

- `apps/mobile/eas.json:53-56` sets preview `EXPO\_PUBLIC\_API\_URL` and `EXPO\_PUBLIC\_APP\_URL` to `https://locateflow.com`.

Impact:

Internal preview builds can hit production data/endpoints by default.

Fix:

Use staging URLs for preview/staging profiles and reserve production URL for production profiles only.

M-27: Mobile Family/Pro Store Product Support Is Incomplete

Evidence:

- ``.env.example:80-83`` includes Individual and Family mobile product examples.
- ``.env.production.example:110-113`` includes only Individual monthly/yearly.
- ``packages/shared/src/runtime-config.ts:908-998`` defines only Individual mobile product keys.
- ``apps/mobile/app/settings/subscription.tsx:254-256`` resolves only monthly/yearly SKUs for current purchase UI.

Impact:

Mobile store purchase surface is Individual-only while web pricing exposes Family/Pro. The app does link to web for Family/Pro, but runtime config and product docs are inconsistent.

Fix:

Either formally keep Family/Pro web-only and remove unused mobile Family examples, or add complete Family/Pro mobile product keys, product resolver logic, and store review tests.

Low / Medium-Low Findings

L-01: Admin Impersonation Redaction Comment Does Not Match Logic

Evidence:

- ``apps/admin/src/lib/privacy.ts:181-184`` comments "impersonation context is always SUPER_ADMIN-only" but redacts only when ``!isAdmin``, meaning ADMIN can see ``impersonatedByAdminId``.

Fix:

Redact unless ``role === "SUPER_ADMIN"``.

L-02: Workspace Invitation Duplicate Protection Is Race-Prone

Evidence:

- ``packages/db/prisma/schema.prisma:1909`` unique key is ``[workspaceId, invitedEmail, expiresAt]``.
- ``apps/web/src/app/api/workspaces/[id]/invitations/route.ts:96-103`` does application-level pending-invite check before insert.

Impact:

Parallel invite requests with different expiration times can create duplicate pending invitations.

Fix:

Add a DB-level active/pending uniqueness strategy or transactional lock.

L-03: Workspace Ownership Transfer Can Change Entitlement Anchor Abruptly

Evidence:

Workspace ownership and seat reconciliation use owner subscription as the entitlement source. Code comments and transfer helpers indicate billing anchor follows owner.

Impact:

Transferring a Family workspace to an Individual user can demote the workspace and put members into overflow/read-only state unexpectedly.

Fix:

Require transfer confirmation with plan impact, or require target owner to have sufficient plan before transfer.

L-04: Removed Workspace Member Data Remains in Workspace by Design

Evidence:

`apps/web/src/app/api/workspaces/[id]/members/[memberId]/route.ts` deletes membership but comments that domain data and consent history remain.

Impact:

Owner/admin visibility into removed member data may be a privacy/product-policy issue unless explicitly disclosed.

Fix:

Define removal policy: retain, detach, anonymize, or require explicit export/delete consent. Add audit log and UI disclosure.

L-05: Workspace Plan Feature Comment Mismatch

Evidence:

- ``packages/shared/src/workspace-entitlements.ts:15-16`` says manual connectors are "Family and up".
- ``packages/shared/src/workspace-entitlements.ts:25-29`` sets ``INDIVIDUAL.manualConnectors:true``.

Impact:

Packaging and enforcement can drift.

Fix:

Update comment or plan matrix, and add a test asserting intended manual connector availability.

L-06: Admin API Rate Limiter Is Per-Process

Evidence:

- ``apps/admin/src/middleware.ts:378-416`` uses an in-memory ``Map``.

Impact:

In multi-replica production, limits are per instance and reset on deploy/restart.

Fix:

Use Redis/Upstash or another centralized limiter for admin API writes, login, cron, and internal endpoints.

L-07: Some Mobile URLs Open Raw API/User-Provided Values

Evidence:

- ``apps/mobile/app/custom-providers/[id].tsx`` and ``apps/mobile/app/services/[id].tsx`` open website fields directly.
- ``apps/mobile/app/providers/[id].tsx`` has safer normalization for comparison.

Impact:

Malformed or non-web schemes can launch unexpected handlers or fail poorly.

Fix:

Centralize URL normalization and allow only ``https:`/`http:`` before ``Linking.openURL``.

L-08: Low-Confidence Dead Code / Transitional Code

Observed:

- `apps/web/src/lib/workspace-context.ts` states it is tested but unused/route retrofit comes later.
- Mobile unused-looking style/import entries: auth layout `useMemo`/theme imports, `oauthBtn` styles in sign-in/sign-up, delete-account unused styles.
- `packages/db/prisma/migrate-to-workspaces.smoke.ts` is not obviously wired into root/package scripts.
- Connector `FAILED` state exists in state tests, but persisted worker outcomes mostly flow through queued/dispatching/submitted/confirmed/needs-user.

Recommendation:

Use import graph tooling plus route/navigation-aware checks before deletion. Treat these as cleanup candidates, not immediate remove recommendations.

API Endpoint Risk Matrix

The full route tree was enumerated. High-risk and exception endpoints are listed below because they define the actual risk surface.

Method	Endpoint	File	Auth / Role	Validation	Risk	Recommendation
GET	`/api/profile`	`apps/web/src/app/api/profile/route.ts`	DB user session	Route logic	High data exposure	Return sanitized subscription DTO
PATCH	`/api/addresses/[id]`	`apps/web/src/app/api/addresses/[id]/route.ts`	DB user session	Zod/service logic	High entitlement bypass	Gate `enqueueAddressChange` centrally
POST	`/api/connector-dispatch`	`apps/web/src/app/api/connector-dispatch/route.ts`	DB session + Pro entitlement	Body fallback	Good route gate	Keep route gate, centralize runtime gate
POST	`/api/workspaces/[id]/sync`	`apps/web/src/app/api/workspaces/[id]/sync/route.ts`	Workspace membership	can()	Partial address check	High IDOR/PII leak
POST	`/api/workspaces/[id]/invitations`	`apps/web/src/app/api/workspaces/[id]/invitations/route.ts`	Workspace owner/admin	Body checks	Seat race	Add atomic seat guard
POST	`/api/invitations/[token]/accept`	`apps/web/src/app/api/invitations/[token]/accept/route.ts`	DB user session	Token lookup	Seat race	Lock/serializable transaction
POST	`/api/workspaces/[id]/delete`	`apps/web/src/app/api/workspaces/[id]/delete/route.ts`	Owner + type confirm	Minimal		

Stolen session destructive action | Require step-up challenge |
 | POST | `/api/workspaces/[id]/transfer` |
 `apps/web/src/app/api/workspaces/[id]/transfer/route.ts` | Owner | Target user | Stolen
 session / plan demotion | Require step-up + plan impact confirm |
 | GET | `/api/partner-consents/oauth/callback` | `apps/web/src/app/api/partner-
 consents/oauth/callback/route.ts` | Session + state cookie | OAuth state | Entitlement can
 change during 10-min window | Re-check entitlement/enabled before persist |
 | Internal | connector OAuth token exchange | `apps/web/src/lib/connector-oauth.ts` |
 Runtime config | None for URL destination | SSRF/misconfig | Use hardened connector HTTP
 client rules |
 | POST | `/api/stripe/checkout` | `apps/web/src/app/api/stripe/checkout/route.ts` | DB user
 session | Body/terms | Duplicate past-due, pending inconsistency | Broaden blocking
 statuses, persist pending plan |
 | POST | `/api/subscription/change-plan` | `apps/web/src/app/api/subscription/change-
 plan/route.ts` | DB user session + Stripe subscription | Plan/interval | Pending target
 plan lost | Persist `pendingPlan` |
 | POST | `/api/mobile/iap/verify` | `apps/web/src/app/api/mobile/iap/verify/route.ts` |
 Mobile auth | Zod | Token handling sensitive | Store encrypted token, sanitize profile
 output |
 | Webhook | `/api/webhooks/stripe` | `apps/web/src/app/api/webhooks/stripe/route.ts` |
 Signature route | Stripe event | Central billing authority | Add stale ACTIVE entitlement
 tests |
 | Webhook | `/api/webhooks/playstore` | `apps/web/src/app/api/webhooks/playstore/route.ts`
 | Pub/Sub/webhook logic | Event parsing | Logs token slices | Keep slices short, avoid raw
 token output |
 | GET | Admin dashboard page | `apps/admin/src/app/(admin)/page.tsx` | Any active admin
 page guard | N/A | Business/PII exposure | Gate cards/queries by permission |
 | GET | `/api/users/[id]` admin | `apps/admin/src/app/api/users/[id]/route.ts` |
 `users.canRead` min VIEWER | Param | Broad PII | Role-specific DTO/select |
 | PATCH | `/api/blog/posts/[id]` admin | `apps/admin/src/app/api/blog/posts/[id]/route.ts`
 | Admin blog permission | Sanitizer | Protocol-relative image | Fix image sanitizer |
 | GET | `/api/reports` admin | `apps/admin/src/app/api/reports/route.ts` | Report
 permission | Query | Error detail leak | Generic client error |
 | POST | `/api/internal/security-event` admin | `apps/admin/src/app/api/internal/security-
 event/route.ts` | Internal secret | Event type | Break-glass event rejected | Add event
 type |

Other web/admin route handlers generally use route-level session helpers, middleware prefilters, explicit public allowlists, or internal/cron secrets. No broad unauthenticated admin mutation surface was confirmed.

Billing and Plan Logic Review

Plan matrix from code:

Plan	Seats	Addresses	Services	API Connectors	Notes
Free Trial	1	2	10	No	Setup/trial states
Individual	1	10	100	No	Manual connectors currently true in code
Family	6	17	250	No	Workspace/member features
Pro	10	25	1000	Yes, but annual-only in connector entitlement	Partner hub/advanced export

Primary Family/Pro gaps:

- Environment/runtime config is Individual-first and incomplete for Family/Pro Stripe prices.
- Web settings UI still uses Individual naming/pricing in subscription management.
- Mobile store purchase surface is Individual-only and links Family/Pro to web.
- Scheduled plan changes do not persist target tier.
- Workspace seat enforcement is not atomic.
- Ownership transfer can change the entitlement anchor without obvious step-up/impact guard.

Web Frontend Review

Strong areas:

- Protected app routes are routed through middleware and DB session checks.
- CSP, CSRF, rate-limit, and public path controls are present.
- Error/loading state coverage is stronger than many production apps.
- Vitest coverage is broad: 175 files, 1227 tests.

Key issues:

- Subscription settings are not fully plan-generic.
- Profile API overexposes server subscription fields to clients.
- Workspace sync UI/API needs stricter migration-phase isolation.
- Family/Pro purchase flows need more explicit product/legal copy around annual Pro connector requirements.

Admin Review

Strong areas:

- DB-backed admin sessions and `requirePermission` are present.
- Super-admin/admin role distinctions exist.
- Backup/security/settings/admin modules have many tests.
- Admin middleware has IP rules, CSP, rate-limit policies, and internal/cron route handling.

Key issues:

- Dashboard page guard is too broad for revenue/move/user PII metrics.
- User detail endpoint gives too much nested PII to low-privilege read roles.
- Blog sanitizer has a protocol-relative image gap.
- Break-glass event pipeline drops the emitted event.
- Reports route leaks internal error details.
- Rate limiting is per process.

Mobile Review

Strong areas:

- SecureStore is used for auth token storage.
- API base URL handling forces HTTPS in production fallback.
- Expo/React Native test and typecheck pass.
- Mobile blocks Family/Pro store purchase from wrong Individual checkout and links to web pricing.

Key issues:

- Android manifest is stale versus app.json for invitation links.
- Privacy manifest under-discloses collected data.
- Push enable flow is gated by onboarding soft prompt even from Settings.
- Push/feed href navigation is incomplete.
- Auth guard can mount tabs before onboarding/legal state is known.
- Preview builds point to production API.
- No certificate pinning was found in code; this is not always required, but it is a mobile security consideration.

Database / Migration Review

Strong areas:

- Prisma schema is comprehensive and heavily indexed in hot areas.
- Subscription has hashes for purchase token dedupe.
- Workspace and connector models are present and tested around current flows.

Key issues:

- Raw `purchaseToken` remains plaintext.
- `Address.workspaceId` is nullable during Phase 1 and some runtime paths intentionally allow null.
- `WorkspaceInvitation` uniqueness allows duplicate pending invites under race because

`expiresAt` is part of the unique key.

- `PartnerConsent` lacks unique active grant enforcement.
- Scheduled plan changes need target-plan persistence.

Dependency / Supply Chain Review

Confirmed from local manifests:

- Monorepo uses pnpm `9.15.0`, Turbo `2.9.14`, Node engine `22.x`.
- Local execution used Node `v24.12.0`, producing engine warnings. CI/release should run Node 22 to avoid type/build drift.
- `apps/mobile/package.json` depends on `expo-iap` `^2.8.0`, while root `pnpm.patchedDependencies` references `expo-iap@2.9.7`. This should be verified against the lockfile and patch intent.
- No CVE/advisory claim is made. A delegated `pnpm audit --prod` attempt could not complete due certificate verification (`UNABLE\_TO\_VERIFY\_LEAF\_SIGNATURE`), so external advisory status remains unverified.

Recommended follow-up:

- Run audit in CI/network environment with trusted CA config.
- Run dependency-unused tooling after route/navigation dynamic imports are modeled.
- Pin release Node to 22.x locally/CI/EAS.

Test Gaps and Priority Test Plan

Existing tests passed, but the following cases should be added:

1. Address auto-sync does not enqueue for Individual, Family, Pro monthly, expired Pro, or canceled Pro.
2. Workspace sync rejects `fromAddressId` outside workspace, soft-deleted addresses, null `workspaceId` outside migration mode, suspended/overflow target members.
3. `/api/profile` never returns `purchaseToken`, raw Stripe subscription IDs unless intentionally public, or internal schedule IDs.
4. Active subscription with expired period and stale `lastSyncedAt` does not keep premium forever.
5. Family/Pro checkout pending state persists target plan/source.
6. Scheduled Pro -> Family and Family -> Individual downgrade survives page refresh with correct pending plan.
7. Concurrent invite creation and concurrent invite acceptance cannot exceed seat limits.
8. Workspace delete/transfer requires valid `WorkspaceAuthChallenge`.
9. Blog sanitizer strips `//external-host/path.png`.
10. Admin user detail redacts nested address/budget/support data for VIEWER/MODERATOR.
11. Android app link manifest includes invitations after native config sync.
12. Mobile Settings push enable bypasses onboarding soft-prompt gate after explicit user

intent.

13. Push notification/feed `href` navigates only to allowlisted routes.

14. E2E tests for Individual/Family/Pro plan purchase, downgrade, cancel, grace, and restore flows.

Production Readiness Assessment

Area	Status	Reason
Web core	Mostly ready with fixes needed	Strong tests/middleware, but profile data exposure and billing UI gaps must be fixed
Admin	Needs RBAC tightening	Core auth strong, but dashboard/user detail overexpose data
Mobile	Needs release-config pass	Tests pass, but Android manifest/privacy/push flows need fixes
Billing	Needs Family/Pro hardening	Individual mature; Family/Pro pending/config/UI states incomplete
Workspace	Needs concurrency and step-up	Good foundation, race/step-up/isolation gaps remain
Connectors	Needs entitlement + SSRF hardening	Architecture good, but central gate and OAuth egress controls missing
Observability	Partial	Sentry/logging present; break-glass event drop and stuck dispatch recovery gap remain

Suggested Remediation Order

1. Patch `/api/profile` DTO and encrypt/remove raw `purchaseToken`.
2. Centralize connector entitlement gate inside `enqueueAddressChange`.
3. Validate `fromAddressId`, target member status, and workspace-bound addresses in workspace sync.
4. Add OAuth/token URL SSRF controls and private host/IP rejection.
5. Fix Family/Pro runtime config definitions and production env examples.
6. Make subscription UI plan-generic and persist `pendingPlan`.
7. Add atomic workspace seat enforcement and step-up challenges for delete/transfer.
8. Sync Android native manifest and re-enable Expo doctor config sync check.
9. Fix admin dashboard/user detail RBAC and blog sanitizer.
10. Add regression tests listed above before App Store/Play Store/public Family-Pro launch.

Final Risk Statement

The current codebase is not "unsafe by default"; it has many good security and quality foundations. The risk is concentrated in newly expanded Family/Pro/workspace/connector paths where plan entitlement, workspace isolation, and billing state are not yet consistently enforced across every entry point. Fixing the centralized connector gate, subscription DTO/token storage, workspace sync validation, and Family/Pro billing state

model should be treated as launch-blocking before broad Pro connector or Family workspace rollout.